

Atividade Prática em Grupo – II2

Grupo: Willian Raphael, Giuliano Bruno, Pedro Alexandre e Ayuka

1. Três Vulnerabilidades Presentes no Cenário

- **Privilégios excessivos do usuário:** O usuário opera com privilégios de administrador na máquina, o que facilita que qualquer software malicioso execute alterações profundas no sistema operacional.
- **Ausência de segmentação de rede:** A rede não possui divisões internas, permitindo que um dispositivo infectado se comunique livremente com os servidores internos sem barreiras intermediárias.
- **Falta de monitoramento interno:** O ambiente conta apenas com um firewall de borda, o que significa que o tráfego e as movimentações maliciosas que ocorrem dentro da rede corporativa ficam totalmente invisíveis para a equipe de segurança.

2. Ameaça e Ataque Possíveis

- **Ameaça:** Um *Insider* ou ator malicioso externo utilizando malware (como um Cavalo de Troia ou *Ransomware*) para infiltrar-se na rede através do endpoint desprotegido.
- **Ataque: Movimento Lateral e Escalabilidade de Impacto** — a partir do computador comprometido, o invasor utiliza os privilégios de administrador e a falta de segmentação para navegar livremente pelos servidores internos, roubar dados sensíveis ou criptografar toda a infraestrutura crítica.

3. Três Mecanismos de Segurança Aplicáveis

- **Implementação do Princípio do Menor Privilégio (PoLP):** Remover os direitos de administrador padrão da conta do usuário, limitando o escopo de ação de eventuais softwares maliciosos.
- **Segmentação de Rede (VLANs e Firewalls Internos):** Dividir a rede em zonas de segurança isoladas para impedir o acesso direto e irrestrito entre estações de trabalho e servidores críticos.
- **Solução de Monitoramento Interno (EDR e SIEM):** Adicionar ferramentas de detecção de endpoint e coleta de logs internos para identificar comportamentos anômalos em tempo real dentro da rede.

4. Explicação de Qual Problema Cada Mecanismo Resolvía

- **Princípio do Menor Privilégio:** Resolve o problema do usuário com privilégios de admin, garantindo que um programa desconhecido executado na máquina não consiga modificar arquivos vitais do sistema ou instalar serviços maliciosos.
- **Segmentação de Rede:** Resolve a falta de barreiras internas, impedindo que o comprometimento de um único computador se propague instantaneamente para os servidores da empresa.
- **EDR e SIEM (Monitoramento Interno):** Resolve a cegueira interna da infraestrutura, permitindo detectar a ação de programas desconhecidos e

atividades suspeitas antes que causem danos maiores, já que o firewall de borda não enxerga o tráfego interno.

5. Ordem de Implementação e Justificativa

1. **Fase 1: Contenção Imediata e Rebaixamento de Privilégios**
 - *Ação:* Isolar o computador comprometido da rede, remover o programa desconhecido e retirar os privilégios de administrador da conta do usuário.
 - *Justificativa:* Estanca o problema ativo imediatamente e impede que o atacante continue operando com plenos poderes na máquina afetada.
2. **Fase 2: Implementação de Segmentação de Rede**
 - *Ação:* Configurar VLANs e regras de firewall internas para isolar as estações dos usuários dos servidores de missão crítica.
 - *Justificativa:* Cria barreiras de contenção estruturais, garantindo que futuras infecções em endpoints fiquem confinadas àquela zona específica.
3. **Fase 3: Implantação de Monitoramento Interno (EDR/SIEM)**
 - *Ação:* Instalar agentes de EDR nos computadores e servidores, centralizando os logs em uma ferramenta de SIEM.
 - *Justificativa:* Garante visibilidade contínua de todo o tráfego e comportamento interno, permitindo resposta rápida a incidentes futuros.